Мета - доповнити наявну автентифікацію, захист API та ізоляцію компонентів контролями життєвого циклу даних. Нижче запропоновано архітектуру для навчальної СУМЗ. GDPR і HIPAA застосовуються лише за наявності відповідних територіальних та організаційних умов; їхні вимоги не є взаємозамінними. Конкретну юрисдикцію й остаточні строки зберігання визначає юридична служба закладу.

1 Класифікація даних

Запроваджую чотири рівні чутливості: L1 - публічні довідники без персональних даних; L2 - внутрішні конфігурації та агрегована аналітика з перевіреною анонімністю; L3 - конфіденційні PII, зокрема контакти й облікові дані користувачів; L4 - суворо обмежені медичні записи, діагнози, результати обстежень і дані, що пов'язують особу з лікуванням. Витік L3 створює ризик шахрайства, а L4 - також дискримінації та розкриття стану здоров'я. Технічні журнали мають L2 лише за відсутності персональних даних; IP-адреси й ідентифікатори підвищують їх до L3, медичний контекст - до L4. Псевдонімізована аналітика залишається персональними даними. Мітки GDPR_PERSONAL, GDPR_HEALTH і HIPAA_PHI додаються відповідно до змісту та застосовності регуляторного режиму.

У data catalog реєструються власник набору, класифікація полів, походження даних, дозволені цілі, юрисдикція й retention_policy_id. У БД мітки закріплюються в керованому реєстрі схем, а для записів зі спеціальними обмеженнями - у захищених метаданих. API має опис чутливості полів у схемі OpenAPI; сервер перевіряє політику, фільтрує відповідь і переносить мітки в експорти та події. Клієнт не може сам знизити рівень. Похідний набір успадковує найвищу релевантну чутливість; зниження допускається лише після перевірки анонімізації. Власник даних затверджує класифікацію, автоматичний сканер шукає пропущені PII/PHI, а некласифіковані набори тимчасово отримують L4.

2 Правова підстава та управління згодою

Сервіс consent management зберігає patient_id, перевіреного представника та його повноваження, мету, категорії даних, одержувачів, версію зрозумілого пацієнту тексту, час і спосіб підтвердження, строк дії та статус згоди. Події надання, зміни й відкликання додаються до історії без перезапису попереднього доказу. Пацієнт може окремо погодитися на необов'язкову аналітику та відкликати згоду через кабінет так само просто, як надати її. Відкликання припиняє майбутню обробку, що спирається саме на цю згоду; воно не означає автоматичного видалення всієї медичної історії.

Для кожної мети обробки реєструються legal_basis_id, норма права, юрисдикція, категорії даних і відповідальний. За GDPR потрібні і підстава статті 6, і відповідний виняток статті 9 для медичних даних: наприклад, застосовний правовий обов'язок та надання медичної допомоги за статтею 9(2)(h). Самого договору недостатньо для зняття заборони статті 9. За HIPAA окремо враховуються дозволені використання та розкриття, зокрема для лікування, і authorization там, де вона потрібна. Сервіс політик перевіряє підставу та згоду лише для тих операцій, які від неї залежать; мета задається дозволеним робочим процесом. Відкликання інвалідовує кеш рішень і блокує відповідні фонові завдання.

3 Контроль доступу до даних

Поєдную RBAC, ABAC і tag-based access control. RBAC визначає базові можливості ролей, ABAC перевіряє належність до закладу, зв'язок із лікуванням пацієнта, призначення на зміну, мету операції та довіреність пристрою; мітки визначають додаткові обмеження L3/L4. Policy Decision Point приймає рішення, а Policy Enforcement Point у сервісах примусово його виконує. База додатково застосовує row-level security та обмежені представлення полів. Доступ за замовчуванням заборонений; звичайний запит без підтвердженої політики відхиляється, а не отримує доступ через збій сервісу згод.

Лікар бачить необхідні записи пацієнтів, у лікуванні яких бере участь; медсестра - призначення, спостереження та інші дані, потрібні для її завдань. Реєстратор працює з контактами й записом на прийом, системний адміністратор керує інфраструктурою без штатного доступу до медичного змісту. PoLP забезпечують окремі сервісні акаунти, тимчасові підвищені права та щоквартальний перегляд доступів; need-to-know - перевірка конкретного пацієнта й мети кожного запиту. Екстрений break-glass має окремий контрольований маршрут: посилена автентифікація, причина, мінімальний обсяг, короткий строк, сповіщення та наступний перегляд. Принцип HIPAA minimum necessary має винятки, зокрема для розкриттів і запитів між надавачами допомоги з метою лікування; це не скасовує внутрішнього контролю доступу.

4 Логування та аудит

Audit trail фіксує читання, створення, зміну, видалення, пошук і масовий експорт чутливих записів; дозволені та відхилені запити; зміни ролей, міток, політик і згод; екстрений доступ та передачі партнерам. Приклад події: timestamp=2026-10-24T14:30:00Z; actor=u742; role=doctor; patient_ref=p831; object=encounter/e91; action=read; purpose=treatment; basis=LB12; classification=L4; decision=allow; policy_version=8; request_id=r509. Це вигадані ідентифікатори. У журналі немає діагнозу, тіла API-запиту, пароля чи токена; patient_ref все одно робить його чутливим. Події передаються до окремого сховища append-only/WORM зі строком блокування за retention-політикою, синхронізацією часу, контролем цілісності та сповіщенням про прогалини. Доступ аудиторів також журналюється.

Для відповіді пацієнту система перевіряє особу або повноваження представника й формує витяг за patient_ref: дата, дія, мета, категорія даних та одержувач, коли це застосовно. Відповідальний за приватність перевіряє обсяг права, приховує дані інших осіб і небезпечні технічні деталі та передає результат через захищений кабінет. Внутрішній audit trail не прирівнюється до обов'язку надати весь сирий журнал. HIPAA accounting of disclosures охоплює визначені розкриття за попередні шість років і має винятки, зокрема для treatment, payment, healthcare operations. Для GDPR обсяг витягу визначається правом доступу й правами інших осіб. Запити, строки, рішення та доставку відповіді система відстежує окремо.

5 Строки зберігання та право на видалення

Retention-реєстр задає категорію, початок відліку, строк, правове обґрунтування, власника та legal hold - призупинення видалення через спір або розслідування. Навчальна політика: медичні записи дорослих - 10 років від останнього звернення лише як робоче припущення до перевірки місцевого права; для дітей - окреме правило; контактні дані, потрібні для чинного медичного запису, зберігаються разом із ним. Технічні логи без PHI - 90 днів, псевдонімізовані аналітичні набори - 12 місяців, резервні копії - 35 днів. Аудит чутливих дій - проєктні 6 років із перевіркою пропорційності та місцевих вимог. Обов'язкову HIPAA-документацію зберігаємо щонайменше 6 років від створення або останньої чинності - залежно від того, що пізніше. Це не універсальний строк медичних карт: HIPAA Privacy Rule його не встановлює.

Запит на видалення проходить перевірку особи, пошук пов'язаних копій і оцінку винятків: правовий обов'язок, медичні потреби за застосовним правом, захист правових вимог. За обґрунтованої відмови пацієнт отримує причину; дані обмежуються дозволеною метою. Якщо видалення дозволене, очищаються основна БД, репліки, об'єктне сховище, індекси, кеші та похідні набори. Для аналітики можлива перевірена незворотна анонімізація; маскування та псевдонімізація не дорівнюють стиранню. Незмінні backup ізолюються до завершення циклу, а перед поверненням відновленої копії в експлуатацію повторно застосовується реєстр видалень. Мінімальний доказ виконання зберігається за окремою обґрунтованою політикою. Партнери отримують запит, підтверджують виконання або документують власний обов'язок зберігання; DPA/BAA встановлюють відповідні обов'язки.

6 Шифрування й безпечне тестування

At rest застосовую AES-256 для БД, файлів, журналів і backup, а для особливо чутливих полів - envelope encryption. Ключі розміщуються в KMS/HSM окремо від даних; доступ обмежений, операції журналюються, ротація та відновлення ключів перевіряються. In transit використовую TLS 1.3, а між сервісами - mTLS з перевіркою ідентичності. Ці технології є проєктним вибором, а не твердженням про універсальну вимогу конкретного алгоритму в GDPR/HIPAA. In use звичайний процес обробляє розшифровані дані в пам'яті: для обраних операцій із високим ризиком передбачаю TEE/confidential computing з attestation перед видачею ключа. Для решти - ізоляція процесів, мінімальний час існування відкритих даних, заборона core dump і захищений swap. TEE не усуває ризик помилок самого застосунку.

Dev/test використовують синтетичні пацієнтські записи, сформовані за схемами й правилами предметної області без копіювання production-карт. Середовища мають різні хмарні акаунти, мережі, секрети та ключі; dev-ролі не можуть читати production-БД або відновлювати її backup. CI/CD перевіряє інфраструктурні політики, сканує тестові набори, логи й артефакти на PII/PHI та блокує непогоджені імпорти. Автоматизовані негативні тести перевіряють доступ до чужого пацієнта, підміну мітки, відкликання згоди, експорт без підстави та стирання після відновлення backup. Періодичні перевірки доступів і навчальні відновлення дають докази роботи контролів; один DLP-сканер не забезпечує абсолютної гарантії від витоку.

Залишкові ризики

- Помилки класифікації та втрата міток у похідних наборах - знижуються повторним скануванням і перевіркою власником даних.
- Людський фактор, фотографування екрана та зловживання законним доступом - залишаються можливими; потрібні навчання, моніторинг аномалій і розслідування.
- Складні згоди, представництво дітей і затримка оновлення кешу - можуть спричинити неправильне рішення; потрібні версійність, перевірка повноважень і тести відкликання.
- Повторна ідентифікація аналітичних даних через поєднання наборів - потребує оцінки ризику та обмеження деталізації й малих груп.
- Залишкові копії в backup, незмінних журналах і партнерів - потребують контрольованого завершення retention та підтвердження виконання запитів.
- Компрометація кінцевого пристрою, ключів або застосунку всередині TEE - обмежує ефективність шифрування; потрібні захист пристроїв, контроль ключів і виправлення вразливостей.
- Надмірно сувора політика чи збій consent-сервісу можуть затримати допомогу - необхідні резервування та перевірений екстрений маршрут з аудитом.

Висновок

Запропонований шар пов’язує чутливість даних із метою обробки, правовою підставою, доступом, аудитом і видаленням. Готовність до експлуатації підтверджується тестами політик, доказами виконання retention та перевіркою запитів пацієнтів. Сам перелік технічних контролів не доводить повної відповідності: потрібні також оцінка ризиків приватності, договори, процедури реагування та юридичне погодження.